

COMPANY INFORMATION SECURITY RISK ASSESSMENT

PROJECT CHARTER

Organization	ABC Cloud Technologies Ltd.
Assessment Type	Information Security Risk Assessment
Framework	ISO/IEC 27001:2022
Prepared By	Junior GRC / Cybersecurity Risk Analyst
Version	1.0
Status	Draft
Assessment Date	August 2026
Classification	Internal

Portfolio Project — Fictional Organization / Simulated Assessment

Document Control

Field	Value
Document Name	Company Information Security Risk Assessment — Project Charter
Organization	ABC Cloud Technologies Ltd.
Document Owner	GRC / Security Team
Version	1.0
Classification	Internal
Status	Draft
Framework	ISO/IEC 27001:2022
Assessment Date	August 2026
Review Frequency	Annual or upon significant organizational / technological change

1. Project Objective

The objective of this project is to identify, analyze, evaluate, and treat information security risks affecting ABC Cloud Technologies Ltd.

The assessment follows a risk-based approach aligned with the principles of ISO/IEC 27001:2022 and relevant security control concepts from ISO/IEC 27002:2022.

2. Business Context

ABC Cloud Technologies Ltd. is a fictional Software-as-a-Service (SaaS) organization with approximately 120 employees.

The organization provides cloud-based business software and processes customer, employee, financial, and business information. The company operates primarily using cloud-based services and supports remote working.

3. Assessment Objectives

The assessment is intended to:

- Identify critical information assets.
- Identify relevant threats and vulnerabilities.
- Assess information security risks.
- Evaluate existing security controls.
- Determine residual risk.
- Develop risk treatment recommendations.
- Map relevant risks to ISO/IEC 27001 controls.
- Define appropriate audit evidence.

- Present key findings to management.

4. Scope

The assessment covers the following areas:

- Information assets
- Cloud infrastructure
- End-user devices
- Identity and access management
- Business applications
- Data protection
- Remote working
- Third-party services
- Security monitoring
- Backup and recovery
- Incident management

5. Out of Scope

The following activities are outside the scope of this assessment:

- Penetration testing
- Source-code security testing
- Physical penetration testing
- Detailed network penetration testing
- Forensic investigation
- Actual exploitation of vulnerabilities

6. Assessment Approach

The assessment will follow these stages:

1. Establish context
2. Identify assets
3. Identify threats and vulnerabilities
4. Identify existing controls
5. Assess likelihood
6. Assess impact
7. Determine inherent risk
8. Determine residual risk
9. Develop treatment actions
10. Map risks to relevant ISO controls

- 11. Identify required evidence
- 12. Report findings

7. Risk Assessment Methodology

A 5 × 5 qualitative risk matrix will be used. Likelihood and impact will each be rated from 1 to 5. The resulting risk score is calculated by multiplying likelihood by impact.

Component	Scale	Description
Likelihood	1–5	Estimated probability that the risk event may occur.
Impact	1–5	Estimated consequence to confidentiality, integrity, availability, operations,
Risk Score	Likelihood × Impact	Numerical score used to determine the risk rating.

8. Risk Treatment Options

The following treatment options will be considered:

- Mitigate — implement or strengthen controls to reduce risk.
- Avoid — discontinue or change the activity creating the risk.
- Transfer — share or transfer part of the risk through insurance, contracts, or third parties.
- Accept — formally acknowledge the remaining risk within the organization's risk appetite.

9. Key Stakeholders

Stakeholder	Responsibility
Executive Management	Risk ownership, strategic direction, and approval of significant risk decisions.
IT Manager	IT security implementation and operational technology management.
CISO / Security Lead	Security governance, risk oversight, and security program coordination.
HR Manager	Personnel security, onboarding/offboarding, and awareness coordination.
Legal / Compliance	Regulatory, contractual, and compliance requirements.
System Owners	Protection, availability, and appropriate use of assigned systems and information.
Employees	Compliance with security policies and reporting of security concerns.

10. Expected Deliverables

- Asset Inventory
- Risk Register
- Risk Matrix
- Risk Assessment Report
- Risk Treatment Plan

- ISO/IEC 27001 Control Mapping
- Sample Audit Evidence
- Executive Summary
- Final Risk Assessment Report

11. Assumptions

- This project uses a fictional organization and simulated evidence for portfolio and learning purposes.
- No real organizational confidential information is used.
- The assessment is a simulated GRC exercise and does not constitute an independent certification audit.
- Risk ratings are illustrative and would require validation with actual business and system owners in a real assessment.

12. Approval / Sign-Off

Role	Name	Status	Date
Project Owner / GRC Analyst	Portfolio Project	Prepared	August 2026
Management Representative	Simulated	Pending	—
Risk Owner	Simulated	Pending	—

Note: This document is a simulated portfolio artifact created for demonstration of GRC and information security risk assessment capabilities.